

Segurança da Informação e Governança de TI

TJSC 2026 - Analista de Sistemas - Banca FGV

Aula 01 - Fundamentos de segurança: CID, autenticidade, não repúdio, riscos e controles

Objetivo da aula

Transformar conceitos fundamentais de segurança em acertos de prova: distinguir princípios, reconhecer situações práticas, identificar elementos de risco e classificar controles sem cair nas pegadinhas tradicionais da FGV.

Padrão das questões

As 20 questões são autorais e simulam o estilo FGV: enunciados situacionais, alternativas verossímeis, assertivas combinadas, distratores próximos e distribuição equilibrada de gabarito: 4 respostas por letra.

Material original, elaborado para estudo dirigido. Não reproduz questões reais ou trechos protegidos de materiais comerciais.

Índice

- 1. Como usar esta aula em blocos curtos
- 2. Escopo da aula e conexão com o edital
- 3. Segurança da informação: conceito e pilares
- 4. Confidencialidade, integridade e disponibilidade
- 5. Autenticidade, autorização, auditoria e não repúdio
- 6. Ativos, ameaças, vulnerabilidades e impacto
- 7. Gestão de riscos em TI: probabilidade, impacto e resposta
- 8. Controles de segurança: tipos, natureza e função
- 9. Conexão prática com APIs, Java/Quarkus, Angular e ambiente bancário
- 10. Pegadinhas FGV e mapa mental textual
- 11. Lista de questões sem gabarito
- 12. Gabarito resumido
- 13. Questões comentadas
- 14. Flashcards, siglas e checklist final
- 15. Fontes consultadas

1. Como usar esta aula em blocos curtos

Esta aula cobre a base conceitual que sustenta todo o bloco de Segurança da Informação e Governança de TI. Para a FGV, esse assunto raramente aparece como mera definição isolada: a banca costuma montar uma situação e pedir a classificação correta do princípio afetado, do tipo de risco ou do controle mais adequado.

Como você tem prática com APIs, autenticação, autorização, esteiras e sistemas corporativos, o ganho de desempenho vem de converter vivência em vocabulário de prova. Nesta aula, sempre que aparecer um termo, pense em um sistema real: login de usuário, aprovação de pagamento, trilha de auditoria, indisponibilidade de serviço, vazamento de dados, alteração indevida de registro ou falha operacional.

Roteiro de estudo em 3 blocos

Bloco 1, 35 a 45 min: leia até princípios de segurança. Bloco 2, 35 a 45 min: leia riscos e controles. Bloco 3, 45 a 60 min: resolva as questões sem olhar o gabarito. Depois revise apenas os comentários das que errou ou marcou com dúvida.

Regra de ouro para esta aula

FGV gosta de trocar o nome do princípio. Quando a questão fala em segredo, acesso restrito ou vazamento, pense em confidencialidade. Quando fala em alteração indevida, exatidão ou completude, pense em integridade. Quando fala em acesso no momento necessário, pense em disponibilidade.

2. Escopo da aula e conexão com o edital

Dentro do edital, a disciplina Segurança da Informação e Governança de TI inclui segurança da informação, fundamentos, confidencialidade, integridade, disponibilidade, autenticação, autorização, proteção de dados pessoais, gestão de identidade e acesso, Single Sign On, Keycloak, OAuth2, OpenID Connect, DevSecOps, COBIT 2019, ITIL 4, gestão de riscos e continuidade de serviços. Nesta Aula 1, o foco é a fundação: princípios, riscos e controles.

A banca FGV tende a cobrar a base conceitual de forma aplicada. Em cadernos oficiais de tecnologia e segurança da própria FGV, aparecem questões com situações de risco, tratamento por seguro, engenharia social, IDS/IPS, malwares, criptografia, governança e identificação de ativos. Esse padrão justifica uma aula que vá além de definições curtas.

Alta probabilidade para Aula 1

1) diferenciar confidencialidade, integridade e disponibilidade; 2) distinguir autenticação, autorização e não repúdio; 3) reconhecer ameaça, vulnerabilidade, impacto, ativo e risco; 4) classificar controles preventivos, detectivos, corretivos, compensatórios e administrativos/técnicos/físicos; 5) identificar resposta ao risco: mitigar, transferir, evitar ou aceitar.

3. Segurança da informação: conceito e pilares

Segurança da informação é a proteção da informação e dos sistemas que a processam contra acesso, uso, divulgação, interrupção, modificação ou destruição não autorizados. Na prática de prova, isso se traduz na preservação de três propriedades centrais: confidencialidade, integridade e disponibilidade. Essas três formam a clássica tríade CID, equivalente à sigla inglesa CIA - Confidentiality, Integrity and Availability.

Para não confundir com CIA de agência de inteligência, use o inglês como ferramenta de memorização: Confidentiality lembra segredo; Integrity lembra inteiro, correto, não adulterado; Availability lembra disponível, acessível, utilizável quando necessário.

Além da tríade CID, concursos de TI costumam cobrar autenticidade, autorização, responsabilização, auditoria e não repúdio. A FGV pode chamar esses elementos de objetivos, propriedades, serviços ou princípios de segurança. O nome muda, mas o raciocínio de classificação permanece.

Propriedade	Pergunta de prova	Exemplo corporativo	Controles típicos
Confidencialidade	Quem não deveria ver conseguiu ver?	Usuário acessa dados de processo judicial, cliente, pagamento ou salário sem necessidade de negócio.	Controle de acesso, criptografia, mascaramento, DLP, classificação da informação.
Integridade	O dado foi alterado indevidamente ou ficou incorreto?	Valor de uma transação, status de aprovação ou documento assinado é modificado sem autorização.	Hash, assinatura digital, validação de entrada, controle de versão, logs, segregação de funções.
Disponibilidade	O serviço estava acessível quando o usuário autorizado precisou?	API de pagamentos, sistema judicial ou base de dados fica indisponível no horário crítico.	Redundância, balanceamento, backup, monitoramento, capacidade, continuidade.
Autenticidade	A identidade ou origem é realmente quem afirma ser?	Sistema precisa saber se a requisição veio do usuário, serviço ou instituição esperada.	Certificado, MFA, assinatura digital, autenticação forte, mTLS.
Não repúdio	A parte consegue negar depois o ato praticado?	Aprovação eletrônica, envio de mensagem ou assinatura de documento precisa ser comprovável.	Assinatura digital, carimbo do tempo, logs íntegros, trilha de auditoria.

3.1 Informação, dado, ativo e sistema

Em prova, não restrinja segurança da informação a arquivo digital. Informação pode estar em banco de dados, API, e-mail, documento, log, mensagem em fila, planilha, relatório, backup, tela de sistema ou até conhecimento operacional de uma pessoa. **O ativo é qualquer item que tenha valor para a organização e precise ser protegido.**

Ativos podem ser **primários**, como **informações e processos de negócio**, ou **ativos de suporte**, como **servidores, aplicações, redes, bancos de dados, pessoas, instalações e fornecedores**. Quando a questão descreve uma lista de servidores, aplicações, bases e serviços, geralmente ela está preparando terreno para identificação de ativos antes de ameaças e vulnerabilidades.

4. Confidencialidade, integridade e disponibilidade

4.1 Confidencialidade

Confidencialidade é a propriedade pela qual a informação não fica disponível nem é divulgada a indivíduos, entidades ou processos **não autorizados**. O ponto central é impedir acesso ou exposição indevida.

No seu dia a dia, confidencialidade aparece em **tokens, segredos de aplicação, chaves de API, dados pessoais, dados bancários, documentos internos, logs com informações sensíveis e permissões em sistemas corporativos**. A FGV pode usar verbos como **divulgar, vazar, revelar, expor, consultar indevidamente** ou acessar sem autorização.

Pegadinha FGV

Criptografia em repouso e em trânsito é muito associada à confidencialidade, mas não resolve tudo. Se o usuário indevido tem permissão no sistema, a criptografia pode não impedir a visualização após a autenticação. Nesses casos, o controle mais direto pode ser autorização, segregação de funções ou menor privilégio.

4.2 Integridade

Integridade é a propriedade de **exatidão**, **completude** e **preservação** contra **modificação ou destruição indevida**. O centro da integridade não é segredo, mas **confiabilidade** do conteúdo. Uma informação íntegra é correta, completa e não adulterada de forma não autorizada.

Exemplos: alteração indevida no valor de uma ordem de pagamento; modificação de um documento; corrupção de um backup; inserção de dado falso por falha de validação; alteração de log para ocultar uma ação; modificação de dependência de software em uma esteira.

Hash, assinatura digital, controles de versionamento, trilhas de auditoria, validações de entrada e segregação de funções são controles associados à integridade. No entanto, hash sozinho não garante autoria; ele indica alteração. Assinatura digital agrega integridade, autenticidade e não repúdio, desde que a chave privada esteja protegida.

4.3 Disponibilidade

Disponibilidade é a propriedade de estar **acessível** e **utilizável sob demanda** por **entidade autorizada**. O foco é continuidade do acesso ao serviço, ao dado ou ao recurso quando necessário.

Indisponibilidade pode ser causada por falha de hardware, erro de configuração, sobrecarga, ataque de negação de serviço, desastre físico, falha de rede, indisponibilidade de fornecedor, implantação defeituosa ou expiração de certificado. A FGV pode usar expressões como sistema fora do ar, lentidão extrema, acesso intermitente, serviço inacessível ou indisponível no horário crítico.

Situação	Princípio mais diretamente afetado	Por quê?
Credencial de acesso de administrador foi compartilhada em canal inadequado.	Confidencialidade	Um segredo de autenticação foi exposto a quem não deveria ter acesso.
Valor de pagamento foi alterado após aprovação.	Integridade	O conteúdo da transação perdeu exatidão/confiabilidade.
Sistema judicial fica fora do ar no prazo final de peticionamento.	Disponibilidade	Usuários autorizados não conseguem acessar o serviço quando precisam.
Usuário nega ter aprovado uma operação eletrônica.	Não repúdio	A discussão é prova de autoria/participação posterior ao ato.
API aceita requisição de serviço que se passa por outro serviço.	Autenticidade	A origem/identidade da entidade não foi comprovada.

5. Autenticidade, autorização, auditoria e não repúdio

5.1 Autenticação não é autorização

Autenticação é o processo de verificar a identidade de uma entidade: usuário, sistema, serviço, dispositivo ou aplicação. A pergunta é: quem é você? Autorização é o processo de decidir quais ações ou recursos aquela entidade autenticada pode acessar. A pergunta é: o que você pode fazer?

Essa distinção é campeã de pegadinha. Um usuário pode estar corretamente autenticado e, ainda assim, acessar indevidamente uma funcionalidade se o sistema falhar na autorização. Por exemplo, João faz login com sucesso no portal, mas altera o parâmetro idConta na URL e consulta dados de Maria. A autenticação funcionou; a autorização falhou.

Conceito	Pergunta	Exemplo	Erro comum
Autenticação	Quem é a entidade?	Login, certificado de cliente, token de identidade, MFA.	Achar que login bem-sucedido permite qualquer ação.
Autorização	O que a entidade pode fazer?	Perfil, papel, escopo, política ABAC/RBAC, regra de negócio.	Confundir permissão com prova de identidade.

Conceito	Pergunta	Exemplo	Erro comum
Auditoria	O que ocorreu e como provar?	Logs, trilhas, correlação de eventos, evidências.	Achar que log sozinho impede fraude.
Accountability	Quem responde pelo ato?	Usuário individual, segregação de contas, trilha nominal.	Usar conta compartilhada e perder responsabilização.

5.2 Não repúdio

Não repúdio é a capacidade de impedir que uma parte negue falsamente ter realizado uma ação. Em prova, aparece em contextos de **assinatura digital, aprovação eletrônica, envio/recebimento de mensagem**, transação bancária, submissão de documento ou trilha de auditoria robusta.

Não repúdio é mais forte que mera autenticação. Autenticar o usuário no login ajuda, mas não basta quando se precisa provar posteriormente que ele assinou, enviou, aprovou ou recebeu determinado conteúdo. Para isso, entram assinatura digital, certificados, carimbo do tempo, integridade de logs e cadeia de custódia das evidências.

Hack de inglês técnico

Non-repudiation = não repúdio. Repudiate significa negar, rejeitar, renegar. Se a questão fala em impedir que alguém negue autoria ou participação, o caminho é não repúdio, não confidencialidade.

6. Ativos, ameaças, vulnerabilidades e impacto

Gestão de riscos começa com uma linguagem precisa. A FGV explora trocas entre ameaça, vulnerabilidade, incidente, impacto e controle. A forma mais segura de resolver é montar mentalmente a cadeia: ativo exposto + vulnerabilidade explorável + ameaça atuando + evento/incidente + impacto ao negócio.

Termo	Definição prática	Exemplo em sistema corporativo
Ativo	Algo de valor para a organização.	API de pagamentos, base de processos, certificado, segredo, servidor, reputação, continuidade de serviço.
Ameaça	Causa potencial de incidente; agente ou evento que pode explorar uma vulnerabilidade.	Atacante externo, colaborador mal-intencionado, malware, enchente, falha elétrica, erro humano.
Vulnerabilidade	Fraqueza que pode ser explorada por uma ameaça.	Endpoint sem autorização, senha fraca, biblioteca vulnerável, bucket exposto, ausência de backup testado.
Evento	Ocorrência observável, maliciosa ou não.	Tentativa de login, alerta de EDR, pico de tráfego, queda de serviço.
Incidente	Evento ou série de eventos que compromete ou ameaça comprometer segurança.	Vazamento, alteração indevida, indisponibilidade, ransomware.
Impacto	Consequência para missão, imagem, operação, finanças, pessoas ou conformidade.	Paralisação de serviço, sanção regulatória, perda financeira, dano reputacional.
Controle	Medida para modificar risco.	MFA, revisão de acesso, WAF, backup, segregação de funções, criptografia, monitoramento.

6.1 Ameaça não é vulnerabilidade

Ameaça é aquilo que pode causar dano. Vulnerabilidade é a fraqueza que permite ou facilita o dano. Um atacante é ameaça; uma porta administrativa exposta sem MFA é vulnerabilidade. Uma enchente é ameaça; datacenter sem proteção física e sem contingência é vulnerabilidade. Malware é ameaça; estação sem atualização e sem controle de execução é vulnerabilidade.

Macete de prova

Troque por perguntas: Quem ou o quê pode causar o dano? Ameaça. Qual fraqueza permite que isso aconteça? Vulnerabilidade. O que será prejudicado? Ativo. Qual a consequência? Impacto. O que reduz a chance ou o dano? Controle.

7. Gestão de riscos em TI

Risco em segurança da informação costuma ser entendido como combinação entre a **probabilidade de ocorrência de um evento indesejado e seu impacto**. Em linguagem de prova, risco envolve ameaça, vulnerabilidade, probabilidade e consequência. Não é sinônimo de ameaça nem de vulnerabilidade isolada.

A FGV já cobrou, em prova oficial, a ideia de que risco combina consequências de um incidente com sua probabilidade, e também cobrou tratamento de risco por transferência quando a organização decide contratar seguro. Portanto, para esta aula, a resposta por memorização não basta: é preciso reconhecer a estratégia de tratamento descrita no caso.

Elemento	Como aparece no enunciado	Cuidado
Probabilidade	chance, frequência, possibilidade de exploração, tendência de ocorrência	Não confundir com impacto: algo pode ser provável e pouco impactante.
Impacto	dano, prejuízo, efeito no negócio, paralisação, sanção, imagem	Não confundir com probabilidade: algo raro pode ser catastrófico.
Risco inerente	risco antes dos controles	É a exposição bruta, sem considerar salvaguardas.
Risco residual	risco remanescente após controles	Nunca pressuponha risco zero; controle reduz, não elimina necessariamente.
Apetite a risco	nível de risco que a organização aceita buscar ou tolerar	É decisão de gestão, não cálculo técnico isolado.
Tolerância a risco	variação aceitável em relação ao apetite	Usado para limites operacionais e exceções controladas.

7.1 Respostas ou tratamentos de risco

Tratamento de risco é a decisão sobre o que fazer com o risco identificado. Em concursos, a banca costuma trabalhar quatro respostas clássicas: mitigar, transferir, evitar e aceitar. Algumas referências usam reduzir no lugar de mitigar e compartilhar no lugar de transferir.

Resposta	Ideia central	Exemplo
Mitigar / reduzir	Implementar controles para diminuir probabilidade e/ou impacto.	Aplicar MFA, corrigir vulnerabilidade, segmentar rede, monitorar, revisar acessos.
Transferir / compartilhar	Passar parte do impacto para terceiro, sem eliminar responsabilidade final.	Contratar seguro, terceirizar parte do serviço com SLA e cláusulas contratuais.
Evitar	Deixar de executar a atividade que gera o risco.	Descontinuar endpoint inseguro ou cancelar integração sem requisitos mínimos.
Aceitar	Assumir conscientemente o risco dentro do apetite definido.	Manter risco residual baixo documentado, com aprovação formal.

Pegadinha sobre seguro

Seguro não é mitigação técnica. Ele pode reduzir o impacto financeiro líquido para a organização, mas a categoria clássica de tratamento é transferência/compartilhamento do risco. A causa do incidente pode continuar existindo.

7.2 Avaliação qualitativa e quantitativa

A avaliação qualitativa usa escalas como baixo, médio e alto. É comum em ambientes onde não há dados financeiros suficientes ou onde se precisa priorizar rapidamente. A avaliação quantitativa tenta estimar valores numéricos, como perda esperada, custo de indisponibilidade e exposição financeira. Para TJSC/FGV, o mais provável nesta aula é identificação conceitual, não cálculo avançado.

Em uma matriz de risco simples, risco alto pode surgir de probabilidade alta com impacto alto, mas também de impacto muito alto ainda que a probabilidade não seja extrema. A banca pode tentar induzir o candidato a olhar só para a probabilidade. Não caia: risco é combinação.

8. Controles de segurança

Controles de segurança são **medidas administrativas, técnicas ou físicas adotadas para reduzir, detectar, corrigir, compensar ou responder a riscos**. A FGV pode pedir a classificação por natureza, por momento de atuação ou por finalidade.

8.1 Classificação por natureza

Natureza	Também chamado de	Exemplos
Administrativo	Gerencial, organizacional, processual	Política de segurança, norma de acesso, treinamento, gestão de fornecedores, análise de risco, segregação de funções.
Técnico	Lógico	MFA, firewall, criptografia, controle de acesso, SIEM, DLP, WAF, antivírus/EDR, IAM, logs.
Físico	Ambiental ou patrimonial	Catraca, sala-cofre, controle de visitantes, CFTV, biometria física, climatização, energia redundante.

8.2 Classificação por função ou momento

Tipo	Finalidade	Exemplo
Preventivo	Evitar ou reduzir a chance de ocorrência.	MFA, hardening, treinamento, menor privilégio, validação de entrada, bloqueio de porta.
Detectivo	Identificar ocorrência ou tentativa.	Monitoramento, IDS, SIEM, alerta de login anômalo, auditoria de logs.
Corretivo	Corrigir causa ou efeito após ocorrência.	Aplicar patch, restaurar configuração, remover malware, corrigir regra de acesso.
Recuperativo	Restabelecer operação após falha/incidente.	Restore de backup, site de contingência, failover, plano de recuperação.
Dissuasivo	Desestimular comportamento indevido.	Aviso de monitoramento, sanções previstas, câmeras visíveis, campanhas.
Compensatório	Reduzir risco quando o controle ideal não é possível.	Revisão manual temporária quando integração automática de autorização ainda não existe.

8.3 Controles e princípios: não decore um para um

Um mesmo controle pode proteger mais de um princípio. Criptografia protege confidencialidade, mas assinatura digital protege integridade, autenticidade e não repúdio. Backup protege disponibilidade e integridade histórica, mas não impede vazamento. Logs apoiam auditoria e responsabilização, mas só têm valor se forem íntegros, protegidos contra alteração e retidos pelo prazo adequado.

Leitura FGV

Quando a alternativa trazer um controle muito conhecido, verifique se ele responde ao problema descrito. Se o problema é alteração indevida, criptografar o banco pode ser insuficiente. Se o problema é disponibilidade, assinatura digital pode ser irrelevante. Se o problema é negar autoria, hash sem identidade associada não resolve não repúdio.

9. Conexão prática com APIs, Java/Quarkus, Angular e ambiente bancário

Pense em uma API RESTful de pagamentos em Java/Quarkus consumida por front-end Angular e integrada a sistemas internos. Segurança não é apenas 'login'. Ela envolve proteger dados, garantir que uma operação aprovada não seja adulterada, manter serviço disponível, registrar evidências e aplicar controles proporcionais ao risco.

Camada	Risco típico	Princípio/controlado relacionado
Angular / front-end	Expor regra sensível apenas no cliente ou permitir manipulação de parâmetros.	Autorização no back-end; validação server-side; integridade da regra de negócio.
API Java/Quarkus	Endpoint aceita ação para recurso de outro usuário.	Falha de autorização; aplicar RBAC/ABAC e checagem de escopo/posse.
Integração	Serviço chamador não é autenticado corretamente.	Autenticidade de serviço; certificado, token, mTLS, validação de origem.
Banco de dados	Alteração indevida em registro crítico.	Integridade; trilhas, controle transacional, segregação, versionamento.
Esteira CI/CD	Biblioteca vulnerável ou segredo exposto em repositório.	Controle preventivo; SAST, SCA, secret scanning, revisão, gestão de dependências.
Operação	Serviço indisponível em horário crítico.	Disponibilidade; redundância, monitoramento, escalabilidade, plano de continuidade.

Em prova, sua experiência prática ajuda, mas cuidado com a resposta 'do mundo real'. A FGV quer a categoria conceitual mais direta. Se o enunciado fala que a pessoa acessou dado que não deveria, marque confidencialidade ou autorização, conforme a pergunta. Se fala que o valor foi modificado, integridade. Se fala que o sistema ficou fora do ar, disponibilidade.

10. Pegadinhas FGV e mapa mental textual

10.1 Pegadinhas prováveis

- Confundir autenticação com autorização: login correto não significa permissão correta.
- Tratar não repúdio como simples autenticação: prova posterior de autoria exige evidência forte.
- Achar que criptografia sempre protege integridade: criptografia pura protege principalmente confidencialidade; integridade depende de MAC, assinatura, modos autenticados ou mecanismos adicionais.
- Confundir ameaça com vulnerabilidade: atacante é ameaça; falha explorável é vulnerabilidade.
- Confundir mitigação com transferência: seguro é transferência/compartilhamento do impacto, não correção técnica da causa.
- Achar que controle detectivo impede ocorrência: ele detecta; quem impede é preventivo.
- Ignorar que controles administrativos também são controles de segurança: política, treinamento e segregação contam.

- Associar backup somente a disponibilidade: backup também ajuda integridade histórica, mas precisa de teste de restauração.

10.2 Mapa mental textual

Segurança da Informação

Segurança da Informação -> protege ativos -> preserva CID -> adiciona autenticidade, autorização, auditoria e não repúdio -> identifica ameaças e vulnerabilidades -> estima risco por probabilidade e impacto -> decide tratamento -> implementa controles administrativos, técnicos e físicos -> monitora risco residual.

10.3 Checklist de memorização antes das questões

- CID = confidencialidade, integridade, disponibilidade.
- Autenticação = identidade; autorização = permissão; auditoria = evidência; accountability = responsabilização.
- Não repúdio = impedir negação posterior de ato praticado.
- Ameaça explora vulnerabilidade e pode gerar incidente com impacto.
- Risco = combinação de probabilidade e impacto/consequência.
- Risco inerente vem antes dos controles; risco residual permanece após controles.
- Mitigar reduz; transferir compartilha; evitar elimina a atividade; aceitar assume formalmente.
- Controle preventivo evita; detectivo identifica; corretivo corrige; recuperativo restaura; compensatório substitui parcialmente.

11. Lista de questões sem gabarito

Instrução

Resolva sem consultar o gabarito. Marque também as questões em que ficou entre duas alternativas; elas valem ouro para revisão ativa.

1. Em um sistema de tramitação processual eletrônica, determinado perfil de usuário autenticado passou a visualizar documentos sigilosos de processos aos quais não estava vinculado. A apuração demonstrou que não houve alteração dos documentos nem indisponibilidade do serviço, mas apenas exposição indevida de informações.

Nessa situação, o princípio de segurança da informação mais diretamente violado foi o da:

- (A) disponibilidade, pois o serviço continuou acessível aos usuários autenticados.
- (B) integridade, pois o controle de perfil não foi suficiente para preservar o estado dos documentos.
- (C) confidencialidade, pois informações foram disponibilizadas a usuário sem autorização adequada.
- (D) autenticidade, pois a identidade do usuário necessariamente deixou de ser verificada.
- (E) não repúdio, pois o usuário poderá negar o acesso realizado posteriormente.

2. Uma equipe de desenvolvimento implementou registro de auditoria para aprovações eletrônicas em uma aplicação crítica. Os registros contêm identificador individual do aprovador, data e hora sincronizadas, hash do conteúdo aprovado e proteção contra alteração posterior. O objetivo principal declarado pela área de segurança é dificultar que o aprovador negue, no futuro, a prática do ato.

O objetivo de segurança descrito é mais bem associado a:

- (A) confidencialidade.
- (B) disponibilidade.
- (C) mascaramento.
- (D) anonimização.
- (E) não repúdio.

3. Em uma API corporativa, o usuário João realiza login com sucesso e recebe um token válido. Ao alterar manualmente o identificador do recurso na URL, consegue consultar registros pertencentes a Maria, embora seu perfil não permita essa operação. O mecanismo de login funcionou conforme o previsto.

A falha descrita está relacionada, de forma mais específica, a:

- (A) autenticação, pois qualquer uso de token indica falha na prova de identidade.
- (B) autorização, pois o sistema não restringiu corretamente a ação permitida ao usuário autenticado.
- (C) disponibilidade, pois o endpoint estava acessível no momento da consulta.
- (D) não repúdio, pois não foi mencionada assinatura digital da requisição.
- (E) criptografia, pois a URL deveria estar sempre cifrada no navegador.

4. Durante avaliação de riscos, a equipe identificou uma biblioteca de terceiros com vulnerabilidade conhecida em um microserviço exposto à Internet. Também identificou grupos que exploram ativamente essa falha e estimou que a exploração poderia permitir execução remota de código, com paralisação de serviço crítico.

No cenário descrito, a biblioteca vulnerável, os grupos exploradores e a paralisação potencial correspondem, respectivamente, a:

- (A) vulnerabilidade, ameaça e impacto.
- (B) ameaça, vulnerabilidade e controle.
- (C) ativo, ameaça e vulnerabilidade.

- (D) risco, controle e impacto.
- (E) incidente, ativo e ameaça.

5. Uma organização identificou risco de fraude em determinada operação eletrônica. Em vez de encerrar a operação ou simplesmente assumir o risco, decidiu implantar validação em duas etapas, revisão periódica de perfis, alertas de comportamento anômalo e segregação entre solicitante e aprovador.

A resposta ao risco adotada pela organização é classificada como:

- (A) transferência, pois a responsabilidade pelo risco foi passada a terceiros.
- (B) aceitação, pois a organização decidiu manter a operação em funcionamento.
- (C) eliminação, pois qualquer fraude tornou-se tecnicamente impossível.
- (D) mitigação, pois foram adotados controles para reduzir probabilidade e/ou impacto.
- (E) ocultação, pois controles internos reduzem a visibilidade externa do risco.

6. A área de TI avaliou o risco de indisponibilidade de um sistema e decidiu contratar seguro para cobrir parte dos prejuízos financeiros caso determinado incidente ocorra. Nenhum controle técnico adicional foi implantado no ambiente para reduzir a probabilidade da ocorrência.

A estratégia de tratamento de risco predominante nesse caso é:

- (A) mitigar.
- (B) transferir.
- (C) evitar.
- (D) eliminar.
- (E) detectar.

7. Um comitê de segurança comparou duas situações: I. vazamento de credenciais de acesso; II. alteração não autorizada do valor de uma ordem de pagamento; III. indisponibilidade de portal no último dia de prazo. Considerando os princípios clássicos da segurança da informação, as situações I, II e III afetam, predominantemente:

Assinale a alternativa correta.

- (A) integridade, confidencialidade e autenticidade.
- (B) disponibilidade, integridade e confidencialidade.
- (C) não repúdio, disponibilidade e integridade.
- (D) autenticidade, não repúdio e confidencialidade.
- (E) confidencialidade, integridade e disponibilidade.

8. Em um ambiente de produção, a área de segurança implanta monitoramento centralizado de logs para identificar tentativas de acesso indevido, gerar alertas e permitir investigação posterior. O controle não bloqueia, por si só, a tentativa inicial de acesso.

Quanto ao momento/finalidade de atuação, esse controle é melhor classificado como:

- (A) detectivo.
- (B) preventivo.
- (C) dissuasivo.
- (D) físico.
- (E) compensatório obrigatório.

9. Uma instituição pública política formal de segurança, realiza treinamento periódico contra engenharia social, define procedimento de concessão e revogação de acessos e exige aprovação gerencial para exceções. Embora tais medidas não sejam implementadas como software, elas integram o sistema de

controles de segurança.

Essas medidas são exemplos de controles predominantemente:

- (A) criptográficos.
- (B) físicos.
- (C) administrativos.
- (D) recuperativos.
- (E) biométricos.

10. Em uma aplicação de consulta processual, foi implantado mecanismo que exige autenticação forte do usuário, mas a verificação de permissão para cada processo consultado ficou restrita ao front-end. Um atacante autenticado consegue chamar diretamente a API e obter dados de processos fora de sua competência.

A análise mais adequada é a de que:

- (A) a autenticação forte elimina a necessidade de autorização no back-end.
- (B) a confidencialidade não é afetada, pois o atacante estava autenticado.
- (C) a falha principal está na disponibilidade da API, pois ela respondeu a chamada direta.
- (D) a autorização deveria ser aplicada no servidor, pois autenticação não equivale a permissão sobre recursos.
- (E) o problema seria resolvido apenas com aumento do tamanho da chave criptográfica.

11. Considere as afirmativas a seguir sobre risco em segurança da informação. I. Risco pode ser entendido como combinação de probabilidade e impacto de um evento indesejado. II. Vulnerabilidade, isoladamente, é sempre equivalente a incidente. III. Risco residual é aquele que permanece após a consideração ou aplicação de controles.

Está correto somente o que se afirma em:

- (A) I e III.
- (B) I e II.
- (C) II e III.
- (D) I.
- (E) III.

12. Uma organização decide descontinuar uma integração externa porque o fornecedor não atende a requisitos mínimos de segurança e não há alternativa de controle compensatório aceitável dentro do apetite a risco definido. A atividade que gerava a exposição deixa de ser executada.

A resposta ao risco adotada é:

- (A) aceitação.
- (B) transferência.
- (C) evitação.
- (D) detecção.
- (E) retenção não documentada.

13. Em uma sala-cofre, foram instalados controle de entrada por crachá, registro de visitantes, câmeras de vigilância e sensor de temperatura. Em paralelo, no sistema operacional dos servidores, foram configurados logs de acesso e política de senha.

Os controles da sala-cofre e os controles configurados no sistema operacional são, respectivamente, de natureza:

- (A) administrativa e física.
- (B) física e técnica.
- (C) técnica e administrativa.
- (D) detectiva e compensatória.
- (E) criptográfica e lógica.

14. Um relatório informa que determinado sistema possui risco inerente alto. Após implantação de MFA, segregação de funções e monitoramento de comportamento anômalo, a exposição remanescente foi reavaliada como média e formalmente aceita pela alta gestão dentro do apetite a risco estabelecido.

A exposição média descrita após os controles é denominada:

- (A) ameaça persistente.
- (B) risco absoluto.
- (C) vulnerabilidade explorável.
- (D) impacto agregado.
- (E) risco residual.

15. Uma equipe precisa escolher um controle para reduzir a chance de que senhas vazadas sejam suficientes para acesso remoto ao ambiente administrativo. Entre as opções abaixo, a medida mais diretamente preventiva é:

Assinale a alternativa correta.

- (A) gerar relatório mensal de incidentes já encerrados.
- (B) manter cópia impressa da política de segurança na recepção.
- (C) registrar em ata a aceitação do risco de acesso indevido.
- (D) exigir múltiplo fator de autenticação para acesso administrativo.
- (E) contratar seguro contra prejuízos decorrentes de incidente.

16. Uma trilha de auditoria registra que uma transação foi aprovada pela conta genérica 'operador01', compartilhada por vários membros da equipe. Não há mecanismo adicional que vincule o ato a uma pessoa natural específica.

O problema mais relevante para fins de responsabilização é a fragilidade de:

- (A) accountability, pois a conta compartilhada dificulta atribuir a ação a um indivíduo determinado.
- (B) disponibilidade, pois contas genéricas impedem acesso ao sistema.
- (C) confidencialidade, pois toda conta compartilhada criptografa dados indevidamente.
- (D) classificação da informação, pois todo log deve ser público.
- (E) redundância, pois o sistema não possui múltiplas contas iguais.

17. Durante análise de segurança, foi constatado que os backups existem e são executados diariamente, mas nunca foram submetidos a teste de restauração. A equipe concluiu que a existência do arquivo de backup, por si só, não comprova capacidade efetiva de retomada do serviço.

A conclusão da equipe é adequada principalmente porque o objetivo relacionado à disponibilidade depende de:

- (A) sigilo absoluto dos arquivos de backup, sendo irrelevante sua restauração.
- (B) capacidade comprovada de recuperar dados e serviços em tempo compatível com a necessidade do negócio.
- (C) eliminação de todos os riscos de integridade antes da primeira cópia.
- (D) assinatura digital de todos os usuários finais nos arquivos copiados.

(E) substituição de controles administrativos por controles físicos.

18. Um sistema calcula hash de um arquivo antes e depois do envio. Ao comparar os valores, identifica que o conteúdo recebido é diferente do conteúdo enviado. Não há, entretanto, garantia de quem produziu o arquivo original, pois o hash não foi assinado nem associado a uma identidade confiável.

A análise correta é a de que o mecanismo descrito apoia principalmente a verificação de:

- (A) confidencialidade, mas não disponibilidade.
- (B) autorização, mas não autenticação.
- (C) integridade, mas não necessariamente autoria ou não repúdio.
- (D) anonimização, mas não mascaramento.
- (E) continuidade, mas não retenção.

19. A direção de uma organização define que riscos de vazamento de dados pessoais acima de determinado nível não serão aceitos sem plano de tratamento aprovado. Essa decisão orienta gestores sobre a quantidade e o tipo de risco que a organização está disposta a assumir para atingir seus objetivos.

O conceito descrito é o de:

- (A) evento de segurança.
- (B) vulnerabilidade residual.
- (C) ameaça qualificada.
- (D) apetite a risco.
- (E) controle corretivo.

20. Em uma revisão de controles, foram listadas as seguintes medidas: I. treinamento contra phishing; II. firewall de aplicação Web; III. catraca e controle de visitantes no datacenter. Considerando a natureza predominante dos controles, I, II e III são, respectivamente:

Assinale a alternativa correta.

- (A) técnico, físico e administrativo.
- (B) físico, técnico e administrativo.
- (C) administrativo, físico e técnico.
- (D) detectivo, corretivo e compensatório.
- (E) administrativo, técnico e físico.

12. Gabarito resumido

Gabarito

1-C, 2-E, 3-B, 4-A, 5-D, 6-B, 7-E, 8-A, 9-C, 10-D, 11-A, 12-C, 13-B, 14-E, 15-D, 16-A, 17-B, 18-C, 19-D, 20-E

Alternativa	Quantidade
A	4
B	4
C	4
D	4
E	4

Distribuição propositalmente equilibrada para treino. Em prova real, não há garantia pública de distribuição perfeitamente proporcional por alternativa; use isso apenas como critério residual de chute, nunca como estratégia principal.

13. Questões comentadas

Questão 1 - Gabarito: C

Em um sistema de tramitação processual eletrônica, determinado perfil de usuário autenticado passou a visualizar documentos sigilosos de processos aos quais não estava vinculado. A apuração demonstrou que não houve alteração dos documentos nem indisponibilidade do serviço, mas apenas exposição indevida de informações.

Nessa situação, o princípio de segurança da informação mais diretamente violado foi o da:

Por que a correta está correta: A alternativa C está correta. O enunciado fala em visualização de documento sigiloso por usuário sem autorização adequada. O núcleo é exposição indevida da informação, logo confidencialidade.

Por que as erradas estão erradas:

A: Disponibilidade seria afetada se o serviço estivesse inacessível ou inutilizável por usuários autorizados; o sistema continuou disponível.

B: Integridade envolveria alteração, destruição ou corrupção do conteúdo; o enunciado diz que não houve alteração.

D: Autenticidade não é a melhor resposta, pois não há indicação de falsa identidade. O usuário estava autenticado, mas acessou o que não podia.

E: Não repúdio envolve impedir negação posterior de ato. Pode haver trilha de acesso, mas o princípio violado diretamente é a confidencialidade.

Erro provável do candidato

Confusão entre acesso indevido e alteração de dado.

Questão 2 - Gabarito: E

Uma equipe de desenvolvimento implementou registro de auditoria para aprovações eletrônicas em uma aplicação crítica. Os registros contêm identificador individual do aprovador, data e hora sincronizadas, hash do conteúdo aprovado e proteção contra alteração posterior. O objetivo principal declarado pela área de segurança é dificultar que o aprovador negue, no futuro, a prática do ato.

O objetivo de segurança descrito é mais bem associado a:

Por que a correta está correta: A alternativa E está correta. O objetivo declarado é impedir negação futura da prática do ato. Isso é não repúdio, reforçado por identificação individual, data/hora, hash e

proteção da evidência.

Por que as erradas estão erradas:

A: Confidencialidade protege contra divulgação indevida, não contra negação posterior de autoria.

B: Disponibilidade trata de acesso/utilização quando necessário.

C: Mascaramento reduz exposição de dados, mas não prova autoria.

D: Anonimização remove possibilidade de associação ao indivíduo; aqui ocorre o contrário, pois a trilha vincula o ato ao aprovador.

Erro provável do candidato

Memorização fraca de non-repudiation.

Questão 3 - Gabarito: B

Em uma API corporativa, o usuário João realiza login com sucesso e recebe um token válido. Ao alterar manualmente o identificador do recurso na URL, consegue consultar registros pertencentes a Maria, embora seu perfil não permita essa operação. O mecanismo de login funcionou conforme o previsto.

A falha descrita está relacionada, de forma mais específica, a:

Por que a correta está correta: A alternativa B está correta. João foi autenticado corretamente, mas o sistema não verificou se ele tinha autorização para acessar o recurso de Maria.

Por que as erradas estão erradas:

A: Autenticação funcionou, segundo o próprio enunciado. A falha está após o login.

C: Disponibilidade não é falha; a API estar acessível não é o problema de segurança principal.

D: Não repúdio não é o ponto central; a questão não discute negação de autoria.

E: HTTPS protege tráfego, mas não corrige autorização quebrada no back-end.

Erro provável do candidato

Pegadinha clássica: autenticação versus autorização.

Questão 4 - Gabarito: A

Durante avaliação de riscos, a equipe identificou uma biblioteca de terceiros com vulnerabilidade conhecida em um microserviço exposto à Internet. Também identificou grupos que exploram ativamente essa falha e estimou que a exploração poderia permitir execução remota de código, com paralisação de serviço crítico.

No cenário descrito, a biblioteca vulnerável, os grupos exploradores e a paralisação potencial correspondem, respectivamente, a:

Por que a correta está correta: A alternativa A está correta. A biblioteca com falha é vulnerabilidade; os grupos que exploram a falha são ameaça; a paralisação de serviço é impacto potencial.

Por que as erradas estão erradas:

B: Inverte ameaça e vulnerabilidade e chama impacto de controle.

C: A biblioteca ou o serviço podem ser ativos, mas a falha específica na biblioteca é vulnerabilidade.

D: Risco é a combinação do cenário, não a biblioteca isolada; controle não são os grupos exploradores.

E: Incidente ainda não ocorreu; o enunciado descreve avaliação de risco.

Erro provável do candidato

Confusão entre ameaça e vulnerabilidade.

Questão 5 - Gabarito: D

Uma organização identificou risco de fraude em determinada operação eletrônica. Em vez de encerrar a operação ou simplesmente assumir o risco, decidiu implantar validação em duas etapas, revisão periódica de perfis, alertas de comportamento anômalo e segregação entre solicitante e aprovador.

A resposta ao risco adotada pela organização é classificada como:

Por que a correta está correta: A alternativa D está correta. A organização manteve a operação e implantou controles para reduzir probabilidade e/ou impacto. Isso é mitigação/redução de risco.

Por que as erradas estão erradas:

A: Não houve transferência para seguradora ou terceiro.

B: Aceitar seria assumir formalmente sem implantar novos controles relevantes.

C: Não há eliminação total do risco; risco zero raramente é conclusão adequada.

E: Ocultação não é resposta clássica de tratamento de risco.

Erro provável do candidato

Achar que manter operação sempre significa aceitar risco.

Questão 6 - Gabarito: B

A área de TI avaliou o risco de indisponibilidade de um sistema e decidiu contratar seguro para cobrir parte dos prejuízos financeiros caso determinado incidente ocorra. Nenhum controle técnico adicional foi implantado no ambiente para reduzir a probabilidade da ocorrência.

A estratégia de tratamento de risco predominante nesse caso é:

Por que a correta está correta: A alternativa B está correta. Seguro é exemplo típico de transferência ou compartilhamento de risco, pois desloca parte do impacto financeiro a terceiro.

Por que as erradas estão erradas:

A: Mitigar exigiria controles para reduzir probabilidade ou impacto técnico/operacional da ocorrência.

C: Evitar seria encerrar a atividade que gera o risco.

D: Eliminar é termo absoluto e geralmente inadequado em gestão de riscos.

E: Detectar é função de controle, não estratégia de tratamento predominante no caso.

Erro provável do candidato

Pegadinha FGV sobre seguro como transferência.

Questão 7 - Gabarito: E

Um comitê de segurança comparou duas situações: I. vazamento de credenciais de acesso; II. alteração não autorizada do valor de uma ordem de pagamento; III. indisponibilidade de portal no último dia de prazo. Considerando os princípios clássicos da segurança da informação, as situações I, II e III afetam, predominantemente:

Assinale a alternativa correta.

Por que a correta está correta: A alternativa E está correta. Credenciais vazadas afetam confidencialidade; valor alterado afeta integridade; portal fora do ar afeta disponibilidade.

Por que as erradas estão erradas:

A: Inverte os dois primeiros princípios.

B: Coloca disponibilidade na primeira situação sem razão.

C: Não repúdio não é o foco de credencial vazada.

D: Autenticidade poderia ser afetada em alguns usos de credencial, mas a sequência clássica pedida pelo enunciado é CID.

Erro provável do candidato

Leitura apressada da sequência I, II e III.

Questão 8 - Gabarito: A

Em um ambiente de produção, a área de segurança implanta monitoramento centralizado de logs para identificar tentativas de acesso indevido, gerar alertas e permitir investigação posterior. O controle não bloqueia, por si só, a tentativa inicial de acesso.

Quanto ao momento/finalidade de atuação, esse controle é melhor classificado como:

Por que a correta está correta: A alternativa A está correta. Monitoramento de logs identifica tentativas e apoia investigação. Como não bloqueia a tentativa inicial, é controle detectivo.

Por que as erradas estão erradas:

B: Preventivo atuaria antes, impedindo ou reduzindo diretamente a chance de ocorrência.

C: Dissuasivo desestimula, como aviso de monitoramento; aqui a função principal é detectar.

D: Físico é natureza do controle, não finalidade; além disso, logs são técnicos/lógicos.

E: Compensatório substitui parcialmente controle ideal; não é o caso descrito.

Erro provável do candidato

Confundir detecção com prevenção.

Questão 9 - Gabarito: C

Uma instituição pública política formal de segurança, realiza treinamento periódico contra engenharia social, define procedimento de concessão e revogação de acessos e exige aprovação gerencial para exceções. Embora tais medidas não sejam implementadas como software, elas integram o sistema de controles de segurança.

Essas medidas são exemplos de controles predominantemente:

Por que a correta está correta: A alternativa C está correta. Políticas, treinamentos, procedimentos e aprovações são controles administrativos ou gerenciais.

Por que as erradas estão erradas:

A: Criptográficos envolveriam cifragem, chaves, assinatura ou mecanismos matemáticos.

B: Físicos envolveriam instalações, barreiras e ambiente físico.

D: Recuperativos visam restaurar serviço após falha/incidente.

E: Biométricos usam características físicas/comportamentais para autenticação.

Erro provável do candidato

Subestimar controles não técnicos.

Questão 10 - Gabarito: D

Em uma aplicação de consulta processual, foi implantado mecanismo que exige autenticação forte do usuário, mas a verificação de permissão para cada processo consultado ficou restrita ao front-end. Um atacante autenticado consegue chamar diretamente a API e obter dados de processos fora de sua competência.

A análise mais adequada é a de que:

Por que a correta está correta: A alternativa D está correta. Autenticação forte não substitui autorização. A decisão sobre acesso ao recurso deve ser aplicada no back-end/API, não apenas no cliente.

Por que as erradas estão erradas:

A: É justamente o erro do cenário: autenticação não elimina autorização.

B: Confidencialidade pode ser afetada, pois dados fora da competência foram obtidos.

C: A disponibilidade da API não é o problema central.

E: Criptografia mais forte não corrige lógica de autorização quebrada.

Erro provável do candidato

Responder com solução técnica famosa sem mapear o problema.

Questão 11 - Gabarito: A

Considere as afirmativas a seguir sobre risco em segurança da informação. I. Risco pode ser entendido como combinação de probabilidade e impacto de um evento indesejado. II. Vulnerabilidade, isoladamente, é sempre equivalente a incidente. III. Risco residual é aquele que permanece após a consideração ou aplicação de controles.

Está correto somente o que se afirma em:

Por que a correta está correta: A alternativa A está correta. I define risco em termos de probabilidade e impacto. III define risco residual como o que permanece após controles. II é falsa porque vulnerabilidade não é incidente; ela pode ser explorada e contribuir para um incidente.

Por que as erradas estão erradas:

B: Inclui a II, que confunde vulnerabilidade com incidente.

C: Inclui a II e exclui a I, que está correta.

D: Ignora a III, também correta.

E: Ignora a I, também correta.

Erro provável do candidato

Confusão entre vulnerabilidade, evento e incidente.

Questão 12 - Gabarito: C

Uma organização decide descontinuar uma integração externa porque o fornecedor não atende a requisitos mínimos de segurança e não há alternativa de controle compensatório aceitável dentro do apetite a risco definido. A atividade que gerava a exposição deixa de ser executada.

A resposta ao risco adotada é:

Por que a correta está correta: A alternativa C está correta. A organização deixou de executar a atividade que gerava o risco. Isso caracteriza evitação do risco.

Por que as erradas estão erradas:

A: Aceitação manteria a exposição conscientemente, sem encerrar a atividade.

B: Transferência envolveria seguro, contrato ou compartilhamento do impacto.

D: Detecção é função de controle, não resposta principal no caso.

E: Retenção não documentada não é tratamento adequado e não corresponde ao enunciado.

Erro provável do candidato

Confundir evitar com mitigar.

Questão 13 - Gabarito: B

Em uma sala-cofre, foram instalados controle de entrada por crachá, registro de visitantes, câmeras de vigilância e sensor de temperatura. Em paralelo, no sistema operacional dos servidores, foram configurados logs de acesso e política de senha.

Os controles da sala-cofre e os controles configurados no sistema operacional são, respectivamente, de natureza:

Por que a correta está correta: A alternativa B está correta. Crachá, visitantes, câmeras e sensores na sala-cofre são controles físicos; logs e política de senha no sistema operacional são controles técnicos/lógicos.

Por que as erradas estão erradas:

A: Inverte a classificação.

C: Também inverte e classifica indevidamente controles físicos como técnicos.

D: Detectivo/compensatório é outra dimensão e não classifica corretamente os exemplos.

E: Catraca não é criptográfica; política de senha é lógica/técnica.

Erro provável do candidato

Misturar natureza com função do controle.

Questão 14 - Gabarito: E

Um relatório informa que determinado sistema possui risco inerente alto. Após implantação de MFA, segregação de funções e monitoramento de comportamento anômalo, a exposição remanescente foi reavaliada como média e formalmente aceita pela alta gestão dentro do apetite a risco estabelecido.

A exposição média descrita após os controles é denominada:

Por que a correta está correta: A alternativa E está correta. O risco médio remanescente após MFA, segregação e monitoramento é risco residual.

Por que as erradas estão erradas:

A: Ameaça persistente é agente/campanha, não exposição pós-controle.

B: Risco absoluto não é a categoria clássica cobrada.

C: Vulnerabilidade explorável é fraqueza; não é a exposição consolidada após controles.

D: Impacto agregado é consequência, não nível remanescente de risco.

Erro provável do candidato

Memorização: inerente antes; residual depois.

Questão 15 - Gabarito: D

Uma equipe precisa escolher um controle para reduzir a chance de que senhas vazadas sejam suficientes para acesso remoto ao ambiente administrativo. Entre as opções abaixo, a medida mais diretamente preventiva é:

Assinale a alternativa correta.

Por que a correta está correta: A alternativa D está correta. MFA reduz preventivamente a chance de acesso indevido mesmo se a senha vazar.

Por que as erradas estão erradas:

A: Relatório mensal é posterior e detectivo/corretivo, não preventivo direto.

B: Cópia impressa de política é controle administrativo fraco e não reduz diretamente acesso com senha vazada.

C: Aceitar risco não previne acesso.

E: Seguro transfere parte do impacto financeiro, mas não impede acesso.

Erro provável do candidato

Escolher controle genérico em vez do mais direto.

Questão 16 - Gabarito: A

Uma trilha de auditoria registra que uma transação foi aprovada pela conta genérica 'operador01', compartilhada por vários membros da equipe. Não há mecanismo adicional que vincule o ato a uma pessoa natural específica.

O problema mais relevante para fins de responsabilização é a fragilidade de:

Por que a correta está correta: A alternativa A está correta. Accountability envolve responsabilização e prestação de contas. Conta compartilhada rompe a atribuição individual do ato.

Por que as erradas estão erradas:

B: Disponibilidade não é afetada pelo fato de a conta ser compartilhada.

C: Conta compartilhada pode afetar confidencialidade em alguns cenários, mas o problema descrito é responsabilização.

D: Logs não devem ser públicos por padrão; a questão não discute classificação.

E: Redundância não tem relação com atribuição de autoria.

Erro provável do candidato

Confundir auditoria com mera existência de log.

Questão 17 - Gabarito: B

Durante análise de segurança, foi constatado que os backups existem e são executados diariamente, mas nunca foram submetidos a teste de restauração. A equipe concluiu que a existência do arquivo de backup, por si só, não comprova capacidade efetiva de retomada do serviço.

A conclusão da equipe é adequada principalmente porque o objetivo relacionado à disponibilidade depende de:

Por que a correta está correta: A alternativa B está correta. Backup só sustenta disponibilidade/continuidade se a restauração for testada e compatível com as necessidades de negócio.

Por que as erradas estão erradas:

A: Sigilo dos backups é importante, mas não comprova retomada.

C: Não se exige eliminar todos os riscos para realizar backup.

D: Assinatura de usuários finais não é requisito geral de restauração.

E: Não há substituição necessária de controles administrativos por físicos.

Erro provável do candidato

Achar que backup feito equivale a recuperação garantida.

Questão 18 - Gabarito: C

Um sistema calcula hash de um arquivo antes e depois do envio. Ao comparar os valores, identifica que o conteúdo recebido é diferente do conteúdo enviado. Não há, entretanto, garantia de quem produziu o arquivo original, pois o hash não foi assinado nem associado a uma identidade confiável.

A análise correta é a de que o mecanismo descrito apoia principalmente a verificação de:

Por que a correta está correta: A alternativa C está correta. Hash permite verificar alteração do conteúdo, apoiando integridade. Sem assinatura ou vínculo confiável de identidade, não garante autoria ou não repúdio.

Por que as erradas estão erradas:

A: Hash não torna o conteúdo secreto; não protege confidencialidade por si só.

B: Hash não decide permissão de acesso.

D: Anonimização/mascaramento não são o mecanismo descrito.

E: Continuidade não é o foco; a questão trata de conteúdo alterado.

Erro provável do candidato

Confundir hash com assinatura digital.

Questão 19 - Gabarito: D

A direção de uma organização define que riscos de vazamento de dados pessoais acima de determinado nível não serão aceitos sem plano de tratamento aprovado. Essa decisão orienta gestores sobre a quantidade e o tipo de risco que a organização está disposta a assumir para atingir seus objetivos.

O conceito descrito é o de:

Por que a correta está correta: A alternativa D está correta. A direção define o nível de risco aceitável para atingir objetivos. Isso é apetite a risco.

Por que as erradas estão erradas:

A: Evento de segurança é ocorrência observável, não limite estratégico de aceitação.

B: Vulnerabilidade residual não é o conceito descrito.

C: Ameaça qualificada seria agente/evento com capacidade/intenção, não decisão gerencial.

E: Controle corretivo atua após falha/incidente para corrigir.

Erro provável do candidato

Confundir governança de risco com componente técnico.

Questão 20 - Gabarito: E

Em uma revisão de controles, foram listadas as seguintes medidas: I. treinamento contra phishing; II. firewall de aplicação Web; III. catraca e controle de visitantes no datacenter. Considerando a natureza predominante dos controles, I, II e III são, respectivamente:

Assinale a alternativa correta.

Por que a correta está correta: A alternativa E está correta. Treinamento é administrativo; WAF é técnico/lógico; catraca e controle de visitantes são físicos.

Por que as erradas estão erradas:

A: Inverte o primeiro e o terceiro.

B: Classifica treinamento como físico, o que não procede.

C: Classifica WAF como físico e catraca como técnico, invertendo conceitos.

D: Detectivo, corretivo e compensatório classificam finalidade, não a natureza predominante pedida.

Erro provável do candidato

Atenção ao comando: natureza predominante, não função.

14. Flashcards, siglas e checklist final

14.1 Flashcards

Frente	Verso
O que é confidencialidade?	Propriedade de impedir divulgação ou acesso não autorizado à informação.
O que é integridade?	Propriedade de manter informação correta, completa e não alterada indevidamente.
O que é disponibilidade?	Propriedade de estar acessível e utilizável por entidade autorizada quando necessário.
Autenticação responde a qual pergunta?	Quem é você?
Autorização responde a qual pergunta?	O que você pode fazer/acessar?
O que é não repúdio?	Capacidade de impedir negação posterior falsa de um ato praticado.
Ameaça é o quê?	Causa potencial de incidente: agente ou evento capaz de explorar vulnerabilidade.
Vulnerabilidade é o quê?	Fraqueza explorável em ativo, processo, pessoa, tecnologia ou ambiente.
Risco combina o quê?	Probabilidade e impacto/consequência de evento indesejado.
Risco residual aparece quando?	Após aplicação/consideração de controles.
Seguro é qual tratamento de risco?	Transferência/compartilhamento.
MFA é que tipo de controle no acesso?	Técnico e predominantemente preventivo.
Log é sempre preventivo?	Não. Normalmente é detectivo e de auditoria.
Política de segurança é controle?	Sim, controle administrativo/gerencial.
Backup não testado prova recuperação?	Não. É preciso testar restauração.

14.2 Siglas e acrônimos da aula

Sigla	Expansão	Como cai
CID	Confidencialidade, Integridade e Disponibilidade	Tríade central da segurança da informação.
CIA	Confidentiality, Integrity and Availability	Equivalente em inglês da tríade CID.
MFA	Multi-Factor Authentication	Autenticação multifator; reforça prova de identidade.
IAM	Identity and Access Management	Gestão de identidades e acessos; será aprofundado na Aula 3.
SSO	Single Sign-On	Login único/federado; será aprofundado na Aula 3.
API	Application Programming Interface	Interface de programação de aplicações; muito ligada a autorização e autenticação.
TLS	Transport Layer Security	Protege comunicação em trânsito; aprofundado em criptografia.
DLP	Data Loss Prevention	Prevenção de perda/vazamento de dados.
SIEM	Security Information and Event Management	Correlação e gestão de eventos de segurança.
IDS	Intrusion Detection System	Sistema de detecção de intrusão.
IPS	Intrusion Prevention System	Sistema de prevenção de intrusão.
WAF	Web Application Firewall	Firewall de aplicação Web.
EDR	Endpoint Detection and Response	Deteção e resposta em endpoints.
RTO	Recovery Time Objective	Tempo máximo objetivo para recuperação; será aprofundado na Aula 6.
RPO	Recovery Point Objective	Ponto máximo aceitável de perda de dados; será aprofundado na Aula 6.

14.3 Checklist final

- Consigo explicar CID em exemplos concretos de sistema?
- Sei separar autenticação, autorização, accountability, auditoria e não repúdio?
- Consigo classificar ameaça, vulnerabilidade, ativo, incidente, impacto e controle?
- Sei diferenciar risco inerente e risco residual?
- Sei identificar mitigar, transferir, evitar e aceitar em enunciados situacionais?
- Consigo classificar controles administrativos, técnicos e físicos?
- Consigo classificar controles preventivos, detectivos, corretivos, recuperativos, dissuasivos e compensatórios?
- Errei alguma questão por leitura apressada? Se sim, colocar no caderno de erros com o par conceitual confundido.

15. Fontes consultadas e critério de elaboração

O conteúdo foi elaborado de forma original, com foco no edital TJSC 2026 - Analista de Sistemas - FGV e em padrões de cobrança observados em cadernos oficiais da FGV para cargos de tecnologia/segurança. As questões são autorais e não reproduzem questões reais.

- Edital TJSC nº 10/2026, retificado em 10/04/2026 - conteúdo programático de Analista de Sistemas.
- FGV Conhecimento - Caderno de prova TJSE, Analista Judiciário - Análise de Sistemas - Segurança da Informação, Tipo 1.
- FGV Projetos - Caderno de prova TCE-SE, Analista de Tecnologia da Informação - Segurança da Informação, Tipo 1.

- NIST CSRC Glossary - Information Security; Confidentiality, Integrity and Availability; Non-repudiation.
- NIST Special Publication 800-30 Rev. 1 - Guide for Conducting Risk Assessments.
- NIST Special Publication 800-39 - Managing Information Security Risk.
- Boas práticas consolidadas de segurança, governança e gestão de riscos aplicadas a sistemas corporativos, APIs e ambientes regulados.